

# Sistema de gestión de **identidades y accesos** para el equipo de Casa Monarca.



## Acceso seguro

Protegemos la información y la identidad de quienes ayudan a transformar vidas.

Presentado por Equipo 2:

Ana Lidia Hernández Díaz – A00838643

Ana Paula García Valverde – A01174572

María Fernanda Montoya López – A01743214

Javier Rojas Orrante – A01352213

Xavier Lago Hicks – A01403177

Contexto y objetivo

Fundamentos

Pilares de seguridad

Stack Tecnológico

Arquitectura seg.

Control de Acceso

Validación de Datos

Entrega Única

Servicios Críticos

Interfaz

Resultados

Marco Legal

Futuro

# Contexto y objetivo

Casa Monarca es una organización que atiende a personas migrantes en situación de vulnerabilidad en México.

La gestión de información sensible presenta importantes riesgos:

- Suplantación de identidad de colaboradores.
- Alteración no autorizada de datos.
- Falta de trazabilidad en el acceso a la información.

No existía un sistema centralizado y seguro para gestionar identidades digitales.

Es fundamental implementar un ciclo de vida completo para usuarios que incluya alta, baja, revocación y rastreo conforme a protocolos de seguridad modernos.

Cumplimiento Legal

Gestión Eficiente

Protección de Datos

Contexto y objetivo

Fundamentos

Pilares de seguridad

Stack Tecnológico

Arquitectura seg.

Control de Acceso

Validación de Datos

Entrega Única

Servicios Críticos

Interfaz

Resultados

Marco Legal

Futuro

# Fundamentos y Stack tecnológico



## Clave Pública

Intercambio seguro de información entre usuarios.

## Seguridad en Sesiones

Garantiza la confidencialidad y autenticidad durante la transmisión de datos.

## SQLAlchemy

Mapeo relacional de entidades de seguridad

## Algoritmo RSA

Proporciona autenticación y no repudio mediante la generación de firmas digitales

## FastAPI

Permite crear APIs rápidas y eficientes, facilitando la interacción entre el front-end y back-end

## Pydantic

Herramienta de validación que garantiza la calidad de los datos de entrada



Contexto y objetivo

Fundamentos

Pilares de seguridad

Stack Tecnológico

Arquitectura seg.

Control de Acceso

Validación de Datos

Entrega Única

Servicios Críticos

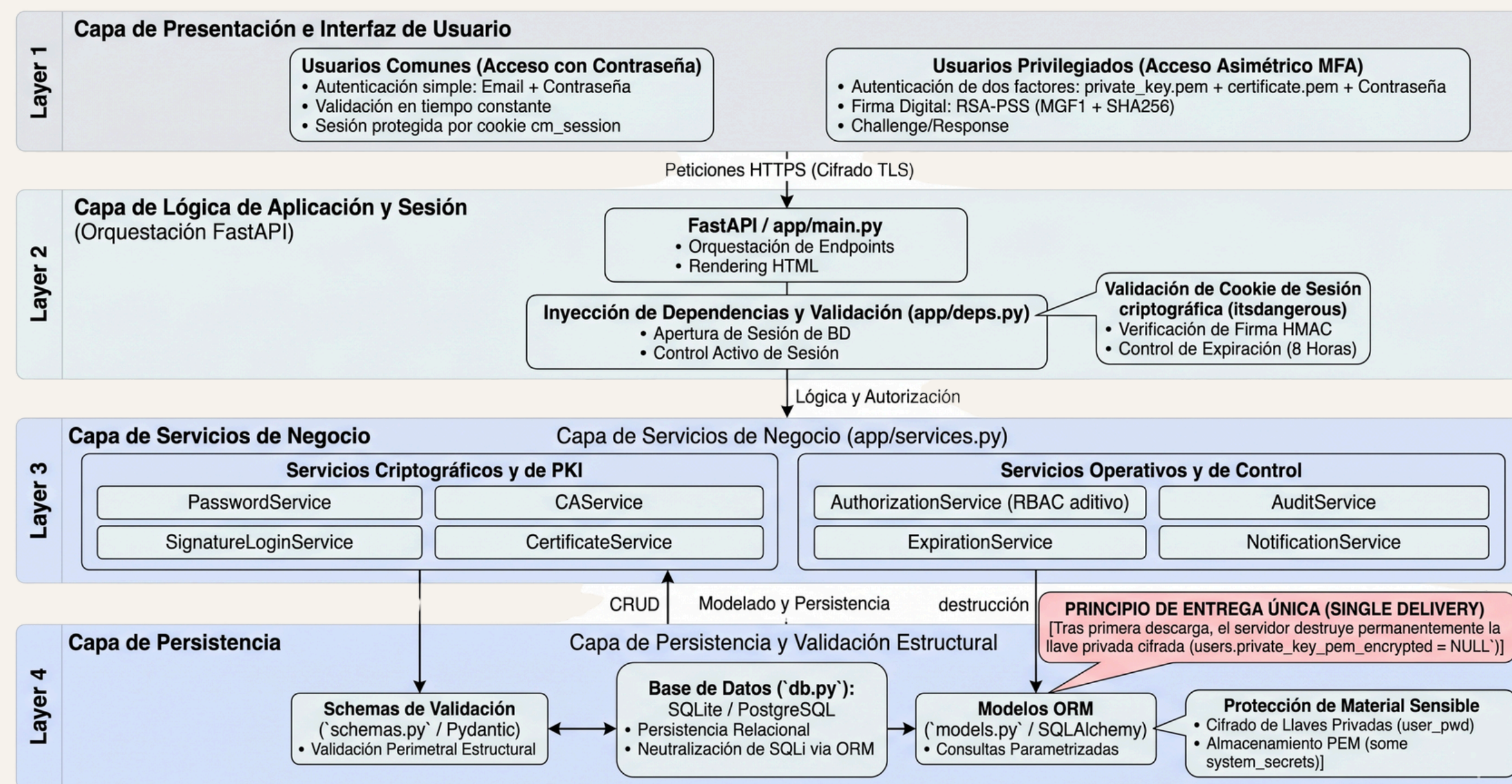
Interfaz

Resultados

Marco Legal

Futuro

# Arquitectura de Capas de Seguridad





Contexto y objetivo

Fundamentos

Pilares de seguridad

Stack Tecnológico

Arquitectura seg.

Control de Acceso

Validación de Datos

Entrega Única

Servicios Críticos

Interfaz

Resultados

Marco Legal

Futuro

# Servicios Críticos del Backend

---

## Gestión de Firmas

El SignatureLoginService procesa autenticación de dos factores, validando certificados X509 y firmas RSA PSS sobre desafíos dinámicos para seguridad robusta.

## Auditoría de Acceso

AuditService captura metadatos de cada petición, registrando detalles como IP, timestamp y acción, garantizando trazabilidad y cumplimiento normativo.

## Autoridad Certificadora

El CertificateAuthorityService actúa como núcleo de confianza, emitiendo certificados firmados a coordinadores y gestionando la CA raíz con un certificado autofirmado.

## Expiración de Usuarios

El ExpirationService evalúa periódicamente el estado de los usuarios, cambiando automáticamente a estado expirado cuando alcanza la fecha de finalización.

Contexto y objetivo

Fundamentos

Pilares de seguridad

Stack Tecnológico

Arquitectura seg.

Control de Acceso

Validación de Datos

Entrega Única

Servicios Críticos

Interfaz

Resultados

Marco Legal

Futuro

# Marco Legal

---

## Derechos ARCO

Los Derechos ARCO permiten a los usuarios acceder, rectificar, cancelar y oponerse al uso de sus datos personales.

## Ley de Protección

La Ley Federal de Protección de Datos Personales garantiza el tratamiento adecuado de la información sensible de los individuos.

## Equilibrio Ético

Se busca un balance entre la robustez criptográfica y la usabilidad, evitando barreras tecnológicas para el personal humanitario.





Contexto y objetivo

Fundamentos

Pilares de seguridad

Stack Tecnológico

Arquitectura seg.

Control de Acceso

Validación de Datos

Entrega Única

Servicios Críticos

Interfaz

Resultados

Marco Legal

Futuro

# Futuro del Proyecto

---

## Integración de Blockchain

Implementar Blockchain asegurará el almacenamiento inmutable de registros, mejorando la transparencia y la seguridad en auditorías de datos.

## Implementación de CRL

Integrar Listas de Revocación de Certificados (CRL) garantizará la invalidación en tiempo real de certificados, mejorando la gestión de riesgos.

## Adopción de WebAuthn

La adopción de estándares WebAuthn permitirá autenticación biométrica, simplificando y fortaleciendo la seguridad sin necesidad de contraseñas complejas.

## Cifrado Homomórfico

La evolución hacia el cifrado homomórfico parcial permitirá realizar búsquedas sobre datos cifrados, aumentando la privacidad y la seguridad operativa.





Gracias



# Librerías



| Librería                  | Versión              | ¿Para qué se usa?                                                                          |
|---------------------------|----------------------|--------------------------------------------------------------------------------------------|
| <code>cryptography</code> | $\geq 43.0.0$        | Generación de llaves RSA, certificados X.509, firmas digitales, cifrado de llaves privadas |
| <code>itsdangerous</code> | $\geq 2.2.0$         | Firma de cookies de sesión con HMAC para evitar falsificación                              |
| <code>hashlib</code>      | (incluido en Python) | Hashing de contraseñas con PBKDF2 y cálculo de hashes SHA-256 para reportes                |
| <code>hmac</code>         | (incluido en Python) | Comparación de hashes en tiempo constante (evita ataques de timing)                        |
| <code>secrets</code>      | (incluido en Python) | Generación de sal aleatoria criptográficamente segura                                      |
| <code>fpdf2</code>        | $\geq 2.7.0$         | Generación de reportes PDF con hash de integridad SHA-256                                  |

# Verificación de documentos

## Paso a paso

1. El usuario sube su `private_key.pem`, su `certificate.pem` y escribe su contraseña.
2. El servidor descifra la llave privada con la contraseña.
3. El servidor verifica que el certificado sea válido (vigente, emitido por la autoridad correcta, serial correcto).
4. El servidor construye un **reto** único:

```
"login:5:coord@casa.org:2026-05-15T10:30:00"
```

5. El servidor firma el reto con la llave privada del usuario.
6. El servidor verifica la firma con la llave pública del certificado.
7. Si la firma es válida → el usuario tiene la llave privada correcta → se le da acceso.

## Esquema de firma

El sistema usa **dos esquemas de firma distintos** para diferentes propósitos:

| Operación                         | Esquema            | ¿Por qué?                                                              |
|-----------------------------------|--------------------|------------------------------------------------------------------------|
| Verificar certificados X.509      | <b>PKCS#1 v1.5</b> | Es el estándar definido por RFC 5280 para certificados                 |
| Firmar/verificar el reto de login | <b>RSA-PSS</b>     | Es más moderno y seguro; cada firma es única gracias a un salt interno |